

Security+ 3.2 · Secure Infrastructures

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 3.2 — Secure Infrastructures (5:54)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Security zones segment the network to control exposure: a DMZ hosts public-facing services between the internet and the internal network, while internal assets remain protected behind it. The attack surface should be minimized—every new connectivity path introduces a new attack vector. Where a service is placed directly determines how exposed it is to attack.

High-Yield Core Concepts Tested on Exam

- Security zones: DMZ separates public-facing services from the internal network
- Attack surface: minimize everything that is externally accessible
- Each new connection = a new port/vector for the attacker
- Service placement determines its exposure level
- Screened subnet (DMZ) allows internet communication but blocks internal access

Exam Tips & Classic Scenarios

- 'place public services between internet and internal network' = DMZ
- 'zone that can talk to the internet but NOT to the internal network' = DMZ/screened subnet

Typical Exam Scenario: A web service must be reachable from the internet but must NOT be able to communicate with internal systems. Place it in a DMZ/screened subnet—a security zone between the internet and the internal network.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 3.2 — Secure Infrastructures)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **SAAS:** Software as a Service: Cloud delivery model where the provider hosts and manages the entire application and infrastructure, with customers consuming the service over the web.
- **PAAS:** Platform as a Service: Cloud model where the provider manages hardware and OS, providing a managed platform for application development and execution.
- **IAAS:** Infrastructure as a Service: Cloud computing model offering raw virtualized computing resources (VMs, storage, networking) managed at the OS level by the customer.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An isolated subnet that exposes public servers (web/email) while protecting the internal network is a:

- A)** Voice VLAN
- B)** DMZ (screened subnet)
- C)** VPN
- D)** Intranet

2. You rent only the virtual machine and manage the OS and everything above. What model is this?

- A) SaaS**
- B) PaaS**
- C) IaaS**
- D) On-premises**

3. Which cloud service model offers the greatest control over the infrastructure, including the operating system and middleware?

- A) SaaS**
- B) PaaS**
- C) IaaS**
- D) FaaS**

4. Corporate scenario (Secure Infrastructures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Zones: DMZ separates public from internal.' What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators using generic credentials**
- D) Implement the corresponding solution: Zones: DMZ separates public from internal.**

5. Corporate scenario (Secure Infrastructures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Attack surface: minimizes everything that is accessible.' What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Implement the corresponding solution: Attack surface: minimizes everything that is accessible...**
- D) Allow shared access among administrators using generic credentials**

6. Corporate scenario (Secure Infrastructures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Each new connection = a new door for the attacker.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Each new connection = a new door for the attacker...

7. Corporate scenario (Secure Infrastructures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'place public services between internet and internal network' = DMZ. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'place public services between internet and internal network' = DMZ...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Secure Infrastructures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'places the web service in a zone that can talk to the internet but NOT to the internal network' = DMZ/screened subnet.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'places the web service in a zone that can talk to the internet but NOT to the internal network' = DMZ/screened subnet.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Secure Infrastructures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Zones: DMZ separates public from internal.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Zones: DMZ separates public from internal...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Secure Infrastructures): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 3.2), an analyst evaluates the following technical requirement: 'Attack surface: minimizes everything that is accessible'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Attack surface: minimizes everything that is accessible
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — DMZ (screened subnet).

✓ **Why it's correct:** The correct answer is 'DMZ (screened subnet)'. A DMZ (Demilitarized Zone), also called a screened subnet, is an isolated network segment that sits between the trusted internal network and the untrusted external network (such as the Internet). It hosts public-facing servers, such as web, email, DNS, and FTP, which need to be accessible externally. The goal is that if one of these servers is compromised, the attacker does not have direct access to the internal network, because firewalls control traffic between the DMZ and the internal network. CompTIA Security+ SY0-701, in the Architecture and Design domain (2.2), describes the DMZ as a security zone for exposing public services in a controlled manner. The question describes exactly this function: an isolated subnet that exposes public servers while protecting the internal network.

✗ **Why the others are wrong:**

- *Voice VLAN:* A voice VLAN is a virtual local area network dedicated to VoIP (Voice over IP) traffic, separating it from data to ensure quality of service (QoS) and security. It is not designed to expose public servers to the Internet; on the contrary, it isolates voice traffic. It does not provide the isolation between internal and external networks that a DMZ provides. Therefore, it does not meet the requirement of protecting the internal network while exposing public services.
- *VPN:* A VPN (Virtual Private Network) is a technology that creates an encrypted tunnel to transmit data securely over untrusted networks, enabling remote access or branch interconnection. Although it improves communication security, it is not an isolated subnet for hosting public servers. A VPN can be used to access the DMZ, but it does not replace the DMZ. The question asks for a network zone that exposes public servers, which is not the primary function of a VPN.
- *Intranet:* An intranet is a private internal network that uses Internet technologies (such as HTTP, FTP) to share information within an organization. It is accessible only to authorized users and is not exposed to the external public. Therefore, it is not used to host public servers that need to be accessed from the Internet. The intranet is the opposite of a DMZ in this respect: it is internal and restricted, not a controlled exposure zone.

2) C — IaaS.

✓ **Why it's correct:** IaaS (Infrastructure as a Service) is the cloud computing model in which the provider offers virtualized infrastructure resources, such as virtual machines, storage, networks, and firewalls, while the customer manages the operating system, middleware, runtime, applications, and data. In the statement, the customer rents only the virtual machine and manages the OS and everything above, which exactly corresponds to the IaaS responsibility division as defined by NIST SP 800-145 and the CompTIA Security+ syllabus (domain 3.1 – Security Architecture and Design).

✗ **Why the others are wrong:**

- *SaaS:* SaaS (Software as a Service) is the model in which the provider delivers complete ready-to-use applications, managing the entire infrastructure stack, operating system, middleware, and the application itself. The customer only accesses the software via web interface or API, without managing the OS or any lower layer. In the described scenario, the customer manages the OS and everything above, which is incompatible with SaaS, where that responsibility belongs to the provider.
- *PaaS:* PaaS (Platform as a Service) offers a managed development and execution environment, including operating system, runtime, middleware, and database services. The customer manages only the applications and data, not the OS. In the statement, the customer manages the OS and everything above, which exceeds the customer's scope of responsibility in PaaS. Therefore, it is not the correct model.

- *On-premises*: On-premises (or on-prem) refers to IT infrastructure installed and maintained physically on the organization's own premises, without cloud involvement. The customer manages everything from hardware to applications, and there is no rental of a virtual machine from an external provider. The statement explicitly describes renting a virtual machine, which characterizes a cloud model, not on-premises.

3) C — IaaS.

✓ **Why it is correct:** The correct answer is IaaS (Infrastructure as a Service). In the IaaS model, the cloud provider delivers fundamental computing resources — virtual machines, block storage, virtual networks, and firewalls — but the customer retains control over the stack from the guest operating system upward. This means the customer is responsible for installing and patching the OS, configuring middleware (application servers, databases, runtimes), managing identities and access policies, and protecting the data. This is the model that offers the greatest degree of control over the infrastructure among the options presented, because the customer can choose the Linux distribution, kernel version, web server, JVM, and so on. CompTIA classifies IaaS as the cloud service model that provides control over the underlying infrastructure, including the OS and middleware, while the provider manages virtualization, physical servers, storage, and the physical network.

✗ **Why the others are wrong:**

- *SaaS*: SaaS (Software as a Service) is the model in which the provider delivers a complete, ready-to-use application, such as Microsoft 365, Salesforce, or Google Workspace. The customer manages nothing in the stack: no access to the operating system, middleware, runtime, database, or infrastructure. All operational and security responsibility from the application down to the physical layer belongs to the provider. Therefore, SaaS offers the least control over the infrastructure, not the most. It is the opposite of what the question asks.
- *PaaS*: PaaS (Platform as a Service) provides a managed environment for developing and running applications, including the operating system, runtime, middleware, and database services already configured and maintained by the provider. The customer controls only the application and, in some cases, limited environment settings. Although it offers more control than SaaS, the customer does not manage the operating system or the middleware — exactly the elements cited in the question. Thus, PaaS does not meet the requirement of greatest control over the OS and middleware.
- *FaaS*: FaaS (Function as a Service) is a serverless computing model in which the customer writes individual functions and the provider fully manages the infrastructure, operating system, runtime, and scaling. The customer's control is limited to the function code and some trigger and memory settings. There is no access to the operating system or middleware, which makes FaaS the model with the least level of control over the infrastructure, not the most.

4) D — Implement the corresponding solution: Zones: DMZ separates public from internal..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Secure Infrastructures): Zones: DMZ separates public from internal. A DMZ is a network zone that acts as a buffer between the public internet and the internal network, hosting public-facing services while protecting internal resources from direct exposure.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: Attack surface: minimizes everything that is accessible....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Secure Infrastructures): Attack surface: minimizes everything that is accessible. Reducing the attack surface involves limiting the number of entry points and vulnerabilities that an attacker could exploit. The correct answer directly reflects this concept by recommending the implementation of the corresponding solution.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: Each new connection = a new door for the attacker....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Secure Infrastructures): Each new connection = a new door for the attacker. This principle emphasizes that every additional network connection or service increases the attack surface, and thus should be minimized or secured. The correct answer directly reflects this concept by recommending the implementation of the corresponding solution.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: 'place public services between internet and internal network' = DMZ....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Secure Infrastructures): 'place public services between internet and internal network' = DMZ. A DMZ (demilitarized zone) is a perimeter network segment that exposes external-facing services to an untrusted network (the internet) while isolating the internal network. This segmentation limits direct access to internal resources and reduces the attack surface.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: 'places the web service in a zone that can talk to the internet but NOT to the internal network' = DMZ/screened subnet..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Secure Infrastructures): 'places the web service in a zone that can talk to the internet but NOT to the internal network' = DMZ/screened subnet. A DMZ (demilitarized zone) or screened subnet is a network segment that hosts externally accessible services while isolating them from the internal network, providing a buffer zone that limits the impact of a compromise.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: Zones: DMZ separates public from internal....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Secure Infrastructures): A DMZ (demilitarized zone) is a network segment that isolates public-facing services from the internal trusted network, enforcing segmentation and reducing attack surface. It is a key architectural control.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Attack surface: minimizes everything that is accessible.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 3.2 (Secure Infrastructures): Attack surface: minimizes everything that is accessible. Reducing

the attack surface involves limiting the number of entry points and services that could be exploited by an attacker, thereby minimizing what is accessible.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.